

# Labbrapport: praktisk laboration

Kunskapskontroll 2, IT-säkerhet för utvecklare.

**Namn:** Athanasios Makedas **Datum:** 2026-08-31 **Repo (länk till din fork):** <https://github.com/ThanosMakedas/SakerLabb> **Applikation som analyserades:** SakerLabb Support

## 1. Kort om applikationen och analysen

SakerLabb Support är ett ärendehanteringssystem i Blazor på .NET 10. Man loggar in, skickar in ärenden, söker, kommenterar och byter status. Det finns också bilagor, import och en adminsida. Datan ligger i en SQLite-fil.

**CodeQL.** Jag forkade repot och slog på code scanning med default setup och språket C#. Första körningen på **main** gav **36 larm**.

**ZAP.** Jag startade appen på <http://localhost:5080> och körde OWASP ZAP 2.17. Med **Manual Explore** klickade jag runt i hela appen medan ZAP gjorde sin **passiva** skanning. Sedan körde jag **Active Scan** på sajten, som skickade 2664 requests. Totalt **17 larm**, varav 3 High.

Efter åtgärderna körde jag samma ZAP-procedur igen och sparade en ny rapport. För CodeQL merge:ade jag branchen **sakerhetsanalys** till **main** via ett pull request, då kördes CodeQL om automatiskt.

## 2. Fem fynd

| Nr | Källa        | Regel-id eller alert                                           | Allvarlighet                   | Fil och rad eller URL                                              | Verkligt eller falskt | Motivering                                                                                                         |
|----|--------------|----------------------------------------------------------------|--------------------------------|--------------------------------------------------------------------|-----------------------|--------------------------------------------------------------------------------------------------------------------|
| 1  | CodeQL + ZAP | SQL query built from user-controlled sources / "SQL Injection" | High · High, Medium confidence | Data/UserRepository.cs:21-22 · POST /account/login, param username | Verkligt              | Båda verktygen hittade det. Jag loggade själv in som admin utan lösenord med ' OR '1'='1' --.                      |
| 2  | CodeQL       | Uncontrolled command line                                      | Critical                       | Services/ImportService.cs:57                                       | Verkligt              | Värddnamnet skickades rakt in i cmd.exe. Med ett & kan man köra egna kommandon, och sidan kräver ingen inloggning. |

| Nr | Källa  | Regel-id eller alert                         | Allvarlighet            | Fil och rad eller URL         | Verkligt eller falskt | Motivering                                                                                     |
|----|--------|----------------------------------------------|-------------------------|-------------------------------|-----------------------|------------------------------------------------------------------------------------------------|
| 3  | ZAP    | Server Leaks Information via "X-Powered-By"  | Low, Medium confidence  | Alla svar från localhost:5080 | Verkligt              | Headern talar om exakt version. Ger ingen åtkomst, men gör det lättare att leta kända buggar.  |
| 4  | ZAP    | Content Security Policy (CSP) Header Not Set | Medium, High confidence | Alla svar från localhost:5080 | Verkligt              | Appen hade inga säkerhetsheaders alls. Appen har XSS, och då behövs CSP som skydd.             |
| 5  | CodeQL | Clear text storage of sensitive information  | High                    | Data/UserRepository.cs:28     | Verkligt              | Lösenordet skrevs i klartext i loggen vid varje inloggning. Loggar läses av fler än databasen. |

**Falskt positivt.** ZAP tog också upp **Path Traversal** (High) på **POST /account/role**, med attacksträngen **role** och tomt evidence-fält. Den koden öppnar inga filer alls, så jag räknar det som falskt positivt och har inte åtgärdat det.

**Bevis.** Bilderna och ZAP-rapporterna ligger i repot under **docs/** i stället för inklistrade här:

**<https://github.com/ThanosMakedas/SakerLabb/tree/sakerhetsanalys/docs>**

| Fil                                          | Visar                                            |
|----------------------------------------------|--------------------------------------------------|
| codeql-fore.png                              | 36 Open / 0 Closed, före                         |
| codeql-fixed-del1.png, codeql-fixed-del2.png | De 17 stängda larmen, alla med "closed as fixed" |
| codeql-efter.png                             | 20 Open / 17 Closed, efter                       |
| zap-fore.html / zap-efter.html               | ZAP-rapporterna före och efter                   |
| zap-korning.png                              | Aktiva skanningen klar, 2664 requests            |

### 3. Prioritering

Jag rangordnade efter hur illa det kan bli, hur lätt det är att komma åt och hur lätt det är att utnyttja.

1. **Fynd 2, kommandoinjektion.** Enda Critical. Egna kommandon på servern är det värsta som kan hända, och sidan kräver ingen inloggning.
2. **Fynd 1, SQL-injektion.** Lika lätt att utnyttja och ger hela databasen. Efter Fynd 2, för kommandon på servern är värre än att läsa databasen.
3. **Fynd 5, lösenord i loggen.** High, men man måste redan ha kommit åt loggarna.

4. **Fynd 4, ingen CSP.** Inget hål i sig, men ett skydd som saknas när appen har XSS.
  5. **Fynd 3, X-Powered-By.** Ger bara information. Fixade det ändå, det tog en minut.
- 

## 4. Åtgärder

### Åtgärd 1

Fynd: 1, SQL query built from user-controlled sources / SQL Injection  
Plats: Data/UserRepository.cs och Data/TicketRepository.cs  
Bevis före: codeql-fore.png, zap-fore.html  
Bedömning: Verkligt, två verktyg hittade det och jag kunde logga in som admin  
Åtgärd: Parametrar i stället för att skriva ihop SQL med strängar.  
Vitlista för ORDER BY. Commit 60369b2  
Bevis efter: 12 larm står som "closed as fixed" i codeql-fixed-del1/del2.png.  
Larmet är borta ur zap-efter.html.

### Åtgärd 2

Fynd: 2, Uncontrolled command line  
Plats: Services/ImportService.cs rad 57  
Bevis före: codeql-fore.png, larm #14  
Bedömning: Verkligt, cmd.exe tolkar & och kör egna kommandon  
Åtgärd: Ping-klassen i .NET i stället för cmd.exe, plus vitlista på värdnamnet. Commit a19c8ee  
Bevis efter: codeql-fixed-del1.png, larm #14 "closed as fixed"

### Åtgärd 3

Fynd: 3, Server Leaks Information via X-Powered-By  
Plats: Program.cs rad 35-40  
Bevis före: zap-fore.html  
Bedömning: Verkligt men lågt, läcker version och maskinamn  
Åtgärd: Tog bort koden som satte headern. Commit a1582c3  
Bevis efter: Larmet är borta ur zap-efter.html

### Åtgärd 4

Fynd: 4, Content Security Policy (CSP) Header Not Set  
Plats: Program.cs  
Bevis före: zap-fore.html, larmet fanns på fem adresser  
Bedömning: Verkligt, inga säkerhetsheaders alls  
Åtgärd: La till CSP, X-Content-Type-Options, X-Frame-Options och Referrer-Policy. Commit e87e2ef  
Bevis efter: Larmet är borta ur zap-efter.html. Samma ändring tog också bort Missing Anti-clickjacking Header och X-Content-Type-Options.

## Åtgärd 5

Fynd: 5, Clear text storage of sensitive information  
Plats: Data/UserRepository.cs rad 28  
Bevis före: codeql-fore.png, larm #13  
Bedömning: Verkligt, lösenordet hamnade i loggen  
Åtgärd: Tog bort lösenordet ur loggraden. Commit b3af444  
Bevis efter: codeql-fixed-del1.png, larm #13 "closed as fixed"

**CodeQL gick från 36 larm till 20. 17 stängdes, alla som **fixed**. Inget dismissat.**

## 5. Eventuella bortval

| Fynd                                                                               | Risk                                                 | Motiv                                                                            | Kompenserande kontroll                                 |
|------------------------------------------------------------------------------------|------------------------------------------------------|----------------------------------------------------------------------------------|--------------------------------------------------------|
| <b>XXE</b> , Critical,<br><code>ImportService.cs:31</code>                         | Inskickad XML kan läsa filer på servern              | Importen används inte, och jag hann inte verifiera en fix med ny körning         | Importvägen används inte, appen körs bara lokalt       |
| <b>XSS</b> , High, <code>Tickets.razor:21</code> ,<br><code>Login.razor:10</code>  | Angriparens skript körs hos den inloggade            | Kräver genomgång av varje <code>MarkupString</code> , större ändring än de andra | CSP:n från Åtgärd 4 blockerar inline-skript            |
| <b>Cookie utan HttpOnly och Secure</b> , Medium,<br><code>AuthService.cs:25</code> | Sessionskakan kan läsas av JavaScript                | Hela inloggningen behöver göras om, inte lagas med två flaggor                   | Appen körs bara lokalt över HTTP                       |
| <b>Log entries from user input</b> , Medium,<br><code>UserRepository.cs:32</code>  | Radbrytningar i användarnamn kan förfalska loggrader | Dök upp först efter Åtgärd 5, inte värt en sjätte åtgärd här                     | Bara användarnamnet loggas, bara vid lyckad inloggning |